Rehabit

RELATÓRIO DE AUDITORIA

Auditoria de segurança do Rehabit

Outubro de 2026

Correções no `main` pelo PR #30 (merge `2280783`, de 13/10/2026), sobre a base `7322333`, que era o `main` depois do PR #29.

36	18	140	79/79	23/23
vulnerabilidades encontradas e corrigidas	problemas achados na reauditoria	testes da API passando	verificações de segurança do site	ponta a ponta com a API real

Documento editável. Os campos dos achados (*conferido*), das ações pendentes (*Feito*, *Responsável*, *Data*, *Observações*) e da revisão final se preenchem em qualquer leitor de PDF; o texto é texto de verdade e pode ser alterado num editor de PDF. O relatório não contém credenciais nem dados pessoais.

Sumário

1. Escopo e método 3

2. Resumo 3

3. Vulnerabilidades da auditoria, correções e testes 4

4. Reauditoria (achados novos, todos corrigidos) 9

5. Testes executados 12

6. Ações fora do código (necessárias) 13

7. Riscos que permanecem e limitações 15

8. Revisão deste relatório 16

1. Escopo e método

Analisado: a API (Spring Boot), o site (Login/ e Software/, publicados pela Vercel), o firmware do goniômetro (ESP32), a configuração (`application*.properties`, `vercel.json`, `.vercelignore`, workflow do GitHub, Dockerfile, `iniciar-rehabit.bat`), as dependências, o banco (`Rehabit.sql` e o mapeamento JPA) e o histórico do repositório.

Como:

1. Leitura do código com o OWASP Top 10 como roteiro: controle de acesso, injeção, XSS, autenticação e sessão, exposição de dados, configuração insegura, componentes desatualizados e tratamento de erros.
2. Reprodução de cada achado **localmente**: API em localhost com H2, site servido localmente com os cabeçalhos do `vercel.json`, navegador sem resolver nenhum host além de localhost. **Nenhuma requisição foi feita à produção** (rehabit.com.br, onrender.com, Vercel, Cloudinary, Brevo, Cloudflare).
3. Antes da correção, cada achado foi confirmado ou descartado por uma segunda verificação independente.
4. Depois das correções, três revisões independentes (API, site e firmware/infra) procuraram desvios das correções e problemas novos. O que encontraram está na seção 4, já corrigido.

Regra de prova: só conta como corrigido o que tem teste. Cada teste de regressão foi rodado também **contra o código antigo** ou com a correção desfeita, para mostrar que ele de fato pega o problema.

2. Resumo

	Crítica	Alta	Média	Baixa	Info	Total
Auditoria (SEC-01 a SEC-36)	3	8	11	11	3	36
Reauditoria (R-01 a R-18)	—	3	3	10	2	18

- **Corrigidos no código, com teste:** todos os achados que dependem só do código.
- **Corrigidos, sem teste possível aqui:** o firmware (só compilação, sem hardware) e o container sem root (sem Docker).
- **Dependem de configuração da produção ou de decisão de projeto:** listados nas seções 6 e 7.

Combinações que aumentavam o risco antes das correções:

- **Chave dos tokens publicada (SEC-01) + token de goniômetro aceito em qualquer rota (SEC-05):** qualquer pessoa com o código-fonte assinava um token de clínica ou de profissional e lia os prontuários de qualquer clínica.
- **XSS armazenado (SEC-02/03/24) + token no localStorage sem CSP (SEC-09):** um profissional mal-intencionado gravava um "nome" ou uma "foto" que, aberto pela clínica, roubava a sessão dela — a conta com mais poder no sistema.
- **Pareamento sem limite (SEC-04) + token de goniômetro valendo nas rotas de tela (SEC-05):** força bruta no código de 6 dígitos de qualquer clínica com pareamento aberto, e depois leitura de dados de outra clínica.
- **Upload público (SEC-07) + tipo pelo nome do arquivo (SEC-06):** HTML hospedado e servido pela própria API.
- **HTTPS sem verificação no firmware (SEC-11) + portal Wi-Fi que abria sozinho com senha pública (SEC-22):** alguém por perto reconfigurava o aparelho para uma rede própria e lia o token (válido por um ano).

3. Vulnerabilidades da auditoria, correções e testes

SEC-01 Crítica — API: `JwtService`, `application.properties` — ☐ conferido

PROBLEMA	Chave dos tokens com valor-padrão escrito no repositório: quem lê o código assina token de qualquer conta.
CORREÇÃO	Sem valor-padrão; em produção a API não sobe sem `REHABIT_JWT_SECRET` (≥ 32 bytes); fora dela, chave sorteada a cada subida.
TESTE	`ChaveDosTokensNaSubidaTest`

SEC-02 Crítica — API (campo `foto`) + site (5 telas) — ☐ conferido

PROBLEMA	XSS armazenado: a foto, texto livre, ia para `style="background-image:url(...)"`; com aspas, virava HTML/script na tela de quem abrisse (profissional → clínica).
CORREÇÃO	API só aceita URL que o próprio armazenamento devolveu; site aplica a foto pelo CSSOM e só aceita http(s)//`/uploads/`.
TESTE	`CampoFotoTest`, `tests/seguranca-front` (xss)

SEC-03 Crítica — Site: ~20 telas — ☐ conferido

PROBLEMA	XSS armazenado: nome, especialidade, observação, notificação etc. montados com `innerHTML` sem escape.
CORREÇÃO	`escaparHtml` único (`& < > " '`) em todo dado que vira HTML.
TESTE	`tests/seguranca-front` (xss, 20+ telas)

SEC-04 Alta — API: `/api/dispositivos/parear` — ☐ conferido

PROBLEMA	Código de pareamento de 6 dígitos sem limite de tentativas: força bruta entregava token de goniômetro de qualquer clínica com código ativo.
CORREÇÃO	Limite de erros por IP (10/10 min) e teto global (30/min).
TESTE	`LimitesDeTentativasTest`

SEC-05 Alta — API: `JwtAuthenticationFilter` — ☐ conferido

PROBLEMA	Token de goniômetro aceito nas rotas de tela: o id do aparelho virava id de profissional de outra clínica (leitura de pacientes, troca de senha).
CORREÇÃO	Token de dispositivo só vale em telemetria/leitura; nas demais, 403.
TESTE	`TokenDoGoniometroSoNasRotasDoAparelhoTest`

SEC-06 Média API: upload ☐ conferido

PROBLEMA	Confiava no Content-Type e na extensão do cliente: HTML/SVG gravados e servidos pela API.
CORREÇÃO	Tipo pelos bytes (JPEG/PNG/GIF/WEBP), extensão do tipo real, SVG recusado; `/uploads/**` só serve imagem, com CSP `sandbox` e `nosniff`.
TESTE	`EnvioDeFotosTest`

SEC-07 Média API: `/api/uploads` ☐ conferido

PROBLEMA	Upload público e sem limite (abuso de armazenamento/cota).
CORREÇÃO	Exige login; foto do cadastro por rota própria que exige e-mail confirmado; limites por IP e por e-mail.
TESTE	`EnvioDeFotosTest`, `FotoDoCadastroTest`

SEC-08 Alta API: telemetria ☐ conferido

PROBLEMA	`"angulo": 1e999999999` fazia o `setScale` montar um número de um bilhão de dígitos: um pacote de 16 bytes travava um núcleo da CPU.
CORREÇÃO	Faixa e dígitos conferidos antes de qualquer conta (DTO + serviço).
TESTE	`AnguloDoGoniometroTest`

SEC-09 Alta Site: `vercel.json` ☐ conferido

PROBLEMA	Sem CSP, HSTS nem Permissions-Policy; token no localStorage sem nenhuma contenção.
CORREÇÃO	CSP sem script inline (o do tema por hash), HSTS, Permissions-Policy, frame-ancestors.
TESTE	`tests/seguranca-front` (estatico, csp)

SEC-10 Alta API: login, cadastro, e-mail, códigos ☐ conferido

PROBLEMA	Sem limite de tentativas; anti-robô opcional.
CORREÇÃO	Limites por IP, por conta e por destinatário; IP só do proxy de confiança.
TESTE	`LimitesDeTentativasTest`

SEC-11 Alta Firmware ☐ conferido

PROBLEMA	`setInsecure()`: HTTPS sem conferir certificado; na mesma rede, dava para se passar pela API e ler o token do aparelho.
CORREÇÃO	Certificado conferido contra 7 raízes embutidas.
TESTE	Compilação nos núcleos 2.0.9 e 3.3.2; conferência do bloco PEM

SEC-12 Média API: exclusão de conta ☐ conferido

PROBLEMA	Apagava qualquer arquivo citado nas linhas da conta: bastava pôr a URL da foto de outra clínica e excluir a conta.
CORREÇÃO	Só apaga arquivo que nenhum cadastro usa mais.
TESTE	`CampoFotoTest`

SEC-13 Média API: fotos de pacientes ☐ conferido

PROBLEMA	Foto trocada nunca era apagada; metadados (GPS) publicados junto.
CORREÇÃO	Foto trocada apagada; EXIF/GPS removidos no envio. Endereço continua público, mas impossível de adivinhar.
TESTE	`CampoFotoTest`, `EnvioDeFotosTest`

SEC-14 Média API: cadastro e login ☐ conferido

PROBLEMA	Enumeração de contas: 409 no código de cadastro, oráculo de tempo no login.
CORREÇÃO	Mesma resposta para quem tem e quem não tem conta; login sem conta gasta o mesmo BCrypt; conflito só depois do e-mail confirmado.
TESTE	`CodigoDeCadastroNaoRevelaContaTest`, `LimitesDeTentativasTest`

SEC-15 Média API: sessão ☐ conferido

PROBLEMA	Tokens de 30 dias sobreviviam à troca e à redefinição de senha.
CORREÇÃO	Troca/redefinição derruba os tokens anteriores; a tela que trocou recebe token novo.
TESTE	`SessaoEncerradaAoTrocarASenhaTest`

SEC-16 Baixa API + site: SSE ☐ conferido

PROBLEMA	Token de sessão na URL do stream.
CORREÇÃO	Ingresso de uso único, 60 s, preso à clínica.
TESTE	`IngressoDoStreamTest`

SEC-17 Média API: DTOs ☐ conferido

PROBLEMA	Textos livres sem limite (TEXT); corpo sem teto.
CORREÇÃO	`@Size` em todos os campos de texto; corpo JSON até 256 KB.
TESTE	`TamanhoDosDadosTest`

SEC-18 Baixa API: telemetria ☐ conferido

PROBLEMA	Ângulos fora da faixa física iam para o prontuário.
CORREÇÃO	Faixa −5° a 185° (bruto ±360°).
TESTE	`AnguloDoGoniometroTest`

SEC-19 Média API: comandos ☐ conferido

PROBLEMA	Com dois aparelhos na clínica, o outro levava a tara/captura/REINICIAR.
CORREÇÃO	Comando vai para o aparelho que estava mandando leituras; REINICIAR registrado em log.
TESTE	`ComandoPorAparelhoTest`

SEC-20 Média API: SSE ☐ conferido

PROBLEMA	Sem teto de conexões.
CORREÇÃO	3 por pessoa (a mais antiga cai), 20 por clínica, 500 no servidor.
TESTE	`GoniometroStreamTest`, `ComandoPorAparelhoTest`

SEC-21 Baixa Firmware ☐ conferido

PROBLEMA	Token em texto claro na memória do ESP32.
CORREÇÃO	Documentado (criptografia da flash queima fusíveis); Revogar anula.
TESTE	— (residual)

SEC-22 Alta Firmware ☐ conferido

PROBLEMA	Portal Wi-Fi com senha publicada abria sozinho e sem tempo limite quando a rede caía.
CORREÇÃO	Com rede salva, só abre segurando o BOOT 2 s, por 3 min.
TESTE	Compilação nos dois núcleos

SEC-23 Média Site ☐ conferido

PROBLEMA	CDN sem SRI e sem versão fixa.
CORREÇÃO	Versão fixa + `integrity` em todas as tags.
TESTE	`tests/seguranca-front` (estatico)

SEC-24 Alta Site ☐ conferido

PROBLEMA	`escaparHtml` não escapava aspas: injeção de atributo em `<option>`.
CORREÇÃO	Escape de `"` e `'`.
TESTE	`tests/seguranca-front` (xss)

SEC-25 Baixa API: dependências ☐ conferido

PROBLEMA	Spring Boot 3.3.0 / Tomcat 10.1.24 desatualizados.
CORREÇÃO	Spring Boot 3.5.16, jjwt 0.12.7.
TESTE	Suíte inteira

SEC-26 Média API: produção ☐ conferido

PROBLEMA	`ddl-auto=update` no PostgreSQL.
CORREÇÃO	Documentado; migrações (Flyway) como próximo passo.
TESTE	— (residual)

SEC-27 Baixa API: tutorial-visto ☐ conferido

PROBLEMA	Qualquer conta marcava o tutorial de outra.
CORREÇÃO	Só a própria conta.
TESTE	`TutorialVistoTest`

SEC-28 Baixa API ☐ conferido

PROBLEMA	Senha mínima de 6, sem lista de comuns.
CORREÇÃO	8 caracteres, máx. 72 bytes, fora das mais comuns.
TESTE	`PoliticaDeSenhaTest`

SEC-29 Baixa Site ☐ conferido

PROBLEMA	Mensagem de erro da API sem escape.
CORREÇÃO	Escapada.
TESTE	`tests/seguranca-front` (xss)

SEC-30 Baixa Site: agenda .ics ☐ conferido

PROBLEMA	Injeção de iCalendar (CR/LF).
CORREÇÃO	Escape de CR/LF, `;`, `,`, `\` e dobra de linha.
TESTE	`tests/seguranca-front` (ics)

SEC-31 Baixa API ☐ conferido

PROBLEMA	`metaAmplitude` com escala absurda → 500.
CORREÇÃO	`@Digits`/faixa → 400.
TESTE	`AnguloDoGoniometroTest`

SEC-32 Baixa API ☐ conferido

PROBLEMA	Upload > 5 MB → 500 com stack trace.
CORREÇÃO	413 com mensagem.
TESTE	`EnvioDeFotosTest`

SEC-33 Baixa API local ☐ conferido

PROBLEMA	H2 com `AUTO_SERVER` (TCP aberto, sa sem senha).
CORREÇÃO	Removido.
TESTE	Revisão de configuração

SEC-34 Info API: validação de e-mail ☐ conferido

PROBLEMA	Consulta DNS de domínio escolhido pelo usuário.
CORREÇÃO	Limites e anti-robô no cadastro; resto documentado.
TESTE	—

SEC-35 Info Vercel ☐ conferido

PROBLEMA	README (detalhes de operação) publicado no site.
CORREÇÃO	`.vercelignore` exclui README e `tests/`.
TESTE	Revisão de configuração

SEC-36 Info `Rehabit.sql` ☐ conferido

PROBLEMA	Linha com hash de senha e e-mail pessoal.
CORREÇÃO	Removida (continua no histórico do git).
TESTE	—

4. Reauditoria (achados novos, todos corrigidos)

R-01 Média API: `LimitePorIpInterceptor` ☐ conferido

PROBLEMA	Limites por IP contornáveis com caminho codificado: `/api/auth/l%6Fgin` chegava ao login sem contar. Reproduzido: 25 tentativas do mesmo IP com teto de 20.
CORREÇÃO	Compara com a rota que o Spring escolheu; HEAD conta como GET.
PROVA	`LimitesDeTentativasTest.caminhoCodificadoNaoFogeDoLimite` (falha sem a correção)

R-02 Média API: código de cadastro ☐ conferido

PROBLEMA	SEC-14 ainda aberto num ponto: o pedido de código respondia 409 "já cadastrado".
CORREÇÃO	Mesma resposta para quem tem e quem não tem conta; o dono da caixa recebe um aviso no lugar do código.
PROVA	`CodigoDeCadastroNaoRevelaContaTest` (falha sem a correção)

R-03 Baixa — API: remarcar consulta — ☐ conferido

PROBLEMA	Observação sem limite de tamanho nessa rota.
CORREÇÃO	Conferida no serviço.
PROVA	`TamanhoDosDadosTest`

R-04 Alta — API: banco — ☐ conferido

PROBLEMA	*Open Session In View* fazia cada stream SSE segurar uma conexão do banco por até 30 min. Com o pool de 10, a 11ª tela do goniômetro derrubava a API inteira.
CORREÇÃO	`spring.jpa.open-in-view=false` (o modelo não tem associações JPA).
PROVA	`IngressoDoStreamTest.telasAbertasNaoSeguramConexaoDoBanco` (falha com o OSIV ligado)

R-05 Baixa — API: SSE — ☐ conferido

PROBLEMA	O 403/429 do stream virava 500 com `Accept: text/event-stream`; o ingresso era emitido para clínica alheia.
CORREÇÃO	Erro do stream sai só com o status; posse conferida já na emissão do ingresso.
PROVA	`IngressoDoStreamTest`

R-06 Baixa — API: fotos — ☐ conferido

PROBLEMA	Metadados que sobreviviam: EXIF em WEBP, blocos privados/C2PA em PNG, comentários em GIF, miniatura no JFIF.
CORREÇÃO	Lista do que fica (e não do que sai) nos quatro formatos.
PROVA	`EnvioDeFotosTest` (4 formatos); fuzz de 80 mil mutações sem travamento nem 500

R-07 Baixa — API: corpo — ☐ conferido

PROBLEMA	O teto de 256 KB era dispensado para qualquer `multipart`; corpo de formulário acima do teto podia virar 500.
CORREÇÃO	Dispensa só nas duas rotas de foto; `FormContentFilter` desligado.
PROVA	`TamanhoDosDadosTest`

R-08 Baixa — API: uploads — ☐ conferido

PROBLEMA	Sem limite por conta; fotos enviadas e nunca usadas ficavam para sempre.
CORREÇÃO	100 por conta por dia; limpeza diária do que ninguém usa (`tb13_arquivo_enviado`).
PROVA	`LimitesDeTentativasTest`, `LimpezaDeEnviosTest`

R-09 Alta Firmware 2.4 ☐ conferido

PROBLEMA	Introduzido na correção do SEC-22: `getWiFiIsSaved()` com o Wi-Fi desligado respondia com lixo da memória. Um aparelho configurado podia abrir o portal sem tempo limite a cada boot.
CORREÇÃO	`WiFi.mode(WIFI_STA)` antes da checagem.
PROVA	Revisão da biblioteca; compilação nos núcleos 2.0.9 e 3.3.2

R-10 Alta Firmware ☐ conferido

PROBLEMA	O portal servia as páginas do WiFiManager para gravar outro firmware e apagar a configuração, sem senha. Por elas se lia o token e a senha do Wi-Fi da clínica.
CORREÇÃO	Rotas respondem 404 e saíram do menu.
PROVA	Revisão da biblioteca; compilação

R-11 Média Firmware ☐ conferido

PROBLEMA	O tempo limite de 3 min renovava a cada página vista.
CORREÇÃO	Conta da abertura (`setWebPortalClientCheck(false)`).
PROVA	Revisão da biblioteca

R-12 Baixa Firmware ☐ conferido

PROBLEMA	No núcleo 3.x o número de série saía do lixo da pilha (um aparelho novo no servidor a cada boot).
CORREÇÃO	MAC lido do eFuse.
PROVA	Compilação

R-13 Baixa Firmware ☐ conferido

PROBLEMA	Código digitado num portal abandonado era usado depois; botão segurado no portal podia virar o reset de 5 s.
CORREÇÃO	Código descartado; o reset só conta um aperto iniciado com o loop rodando.
PROVA	Compilação

R-14 Baixa Infra ☐ conferido

PROBLEMA	Workflow com o token padrão do GitHub; API local aberta para a rede; container como root.
CORREÇÃO	`permissions: {}`; `--server.address=127.0.0.1`; usuário sem privilégio no Dockerfile.
PROVA	Revisão (Docker não testado aqui)

R-15 Baixa Site ☐ conferido

PROBLEMA	`?id=` não numérico ia direto para o caminho da API. Um link forjado fazia "Excluir profissional" revogar um goniômetro, ou "Salvar paciente" sobrescrever a configuração.
CORREÇÃO	`idDaUrl`: id que não é número vira "sem id".
PROVA	Grupo `ids` do `tests/seguranca-front` (falha no commit anterior)

R-16 Baixa Site: goniômetro ☐ conferido

PROBLEMA	Reconexão sem espera crescente, 401 em loop, streams órfãos ao trocar de aba.
CORREÇÃO	Espera de 3 s a 60 s; 401 leva ao login; respostas de tentativas antigas descartadas.
PROVA	PoC da revisão: de 12 req/15 s e 4 streams criados para 3 tentativas e 1 stream

R-17 Info Site: CSP ☐ conferido

PROBLEMA	A CSP confiava em caminhos do jsDelivr (caminhos com `%2F` passavam pela regra).
CORREÇÃO	Bibliotecas servidas pelo próprio site (`vendor/npm/`, bytes iguais aos do npm); nenhum CDN na CSP.
PROVA	Grupo `estatico` (acusa arquivo adulterado) e `csp` (79/79)

R-18 Info Site + API ☐ conferido

PROBLEMA	Token do link de recuperação ficava na barra de endereço e ia num GET (logs de acesso).
CORREÇÃO	Sai da URL ao ser lido; validação por POST.
PROVA	Ponta a ponta (23/23), `LinkDeRecuperacaoTest`

5. Testes executados

Conjunto	Resultado	Onde
API (JUnit + MockMvc, H2 em memória)	**140 passando**, 0 falhas (eram cerca de 60 antes da auditoria)	`cd rehabit-api/rehabit-api && mvn test`
Site (Playwright: estático, XSS em 20+ telas, ICS, CSP em todas as páginas, ids da URL)	**79 de 79**	`node tests/seguranca-front/rodar.js`
Ponta a ponta local (jar + site + Chromium)	**23 de 23**	`node tests/ponta-a-ponta/e2e.js`
Site novo contra a API antiga (o jar do `main` de antes)	**6 de 6**	cadastro com foto, login, goniômetro e link de recuperação
Firmware	Compila sem avisos nos núcleos ESP32 2.0.9 e 3.3.2; bloco de certificados conferido (7 raízes, SHA-256 igual ao repositório da Mozilla)	`arduino-cli compile`

Contraprova no código antigo:

- 18 dos 23 testes novos de fotos, campos, ângulos e tutorial falham no código de antes; os outros 5 são casos de controle.
- No site antigo, mais de 20 telas executam o script injetado; o fuzzer da revisão contou 27 execuções.
- O teste do pool falha com o OSIV ligado.
- O de limite com caminho codificado e o do código de cadastro falham sem as respectivas correções.
- O grupo `ids` falha no commit anterior à correção.

DoS por expoente (SEC-08): medido à parte. `setScale` sobre `1e3000000` já leva 0,7 s, e o crescimento é mais que linear: `1e999999999`, num pacote de 16 bytes, seguraria um núcleo por muitos minutos. Hoje responde 400 na hora.

6. Ações fora do código (necessárias)

1. `REHABIT_JWT_SECRET` **no Render, antes do deploy.** Sem ela a API não sobe em produção. Gere com `openssl rand -base64 64`.
   - Se houver qualquer chance de a produção ter rodado com o valor-padrão antigo (ele está no histórico do git e era usado quando a variável faltava), a troca é obrigatória.
   - Trocar encerra todas as sessões e exige parear de novo todos os goniômetros.

   ☐ **Feito** RESPONSÁVEL _____ DATA _____

   OBSERVAÇÕES

2. **Deploy da API:** o site já está no ar com o merge, mas a API do Render só muda com o deploy dela (*Manual Deploy → Deploy latest commit*), e só sobe com a chave do item 1. Até lá, o site novo continua funcionando com a API antiga:
   - a foto do cadastro e o link de recuperação voltam para as rotas antigas;
   - o goniômetro passa ao polling.

   O banco ganha sozinho a tabela `tb13_arquivo_enviado` e as colunas novas (`ddl-auto=update`).

   ☐ **Feito** RESPONSÁVEL _____ DATA _____

   OBSERVAÇÕES

3 **Firmware 2.4:** testar num aparelho antes de distribuir, depois regravar todos os aparelhos (a 2.3 aceita qualquer certificado). Conferir:

- a cadeia de certificado da produção é aceita;
- um aparelho novo abre o portal sozinho;
- um aparelho configurado não abre o portal depois de REINICIAR.

☐ **Feito** RESPONSÁVEL _____ DATA _____

OBSERVAÇÕES

4 `img-src` **do Cloudinary:** fixar em `https://res.cloudinary.com/<nome-da-conta>/` (o nome está no `CLOUDINARY_URL` do Render).

☐ **Feito** RESPONSÁVEL _____ DATA _____

OBSERVAÇÕES

5 **Senha da conta que estava no** `Rehabit.sql`**:** a linha saiu do arquivo, mas continua no histórico do git. Troque essa senha onde quer que seja usada. Se o e-mail pessoal precisar sumir do histórico, é preciso reescrevê-lo.

☐ **Feito** RESPONSÁVEL _____ DATA _____

OBSERVAÇÕES

6 **Varredura de segredos num clone completo:** este clone é raso e não inclui o histórico anterior a 23/08/2026. Use gitleaks ou trufflehog.

☐ **Feito** RESPONSÁVEL _____ DATA _____

OBSERVAÇÕES

7 **GitHub:**

- Deixe o `GITHUB_TOKEN` padrão como somente leitura.
- Desative a cópia no GitHub Pages ou transforme-a em redirecionamento: ela não recebe a CSP nem o HSTS.

☐ **Feito** RESPONSÁVEL DATA

OBSERVAÇÕES

8 **Clínicas:** ao perder um aparelho, **Revogar** na tela Dispositivo e trocar a senha do Wi-Fi.

☐ **Feito** RESPONSÁVEL DATA

OBSERVAÇÕES

7. Riscos que permanecem e limitações

- **Produção não testada.** Tudo foi verificado localmente; não sei que variáveis o Render tem nem qual a cadeia de certificado real da API.
- **Sessão no localStorage.** Um XSS leria o token. Isso está contido pelo escape único e pela CSP sem script de terceiros; levar o token para cookie HttpOnly exigiria redesenhar a autenticação (site e API em domínios diferentes).
- `style-src 'unsafe-inline'` permanece; injeção de CSS só seria possível com uma injeção de HTML, e nenhuma foi encontrada.
- **Fotos em endereço público.** Os nomes são impossíveis de adivinhar (UUID ou id do Cloudinary) e os metadados são removidos, mas quem tem a URL vê a foto.
- **Goniômetro:**
  - Token (válido por um ano) e senha do Wi-Fi em texto claro na memória: criptografar a flash queima fusíveis.
  - O portal usa uma senha pública: durante os 3 minutos em que fica aberto, alguém por perto pode ler o que é digitado.
  - O certificado não tem validade nem revogação conferidas, porque o aparelho não tem relógio acertado.
- `ddl-auto=update` **em produção.** O próximo passo é passar a migrações versionadas (Flyway) e `validate`.
- **Limites em memória:** zeram quando a API reinicia e valem para uma instância só.
- **Teto global de 500 telas SSE:** muitas contas juntas podem ocupá-lo; quem passa do teto cai para o polling, mais lento, mas funcionando.
- **CORS** `*`**:** não é explorável com token no cabeçalho, mas restringir às origens do site é um endurecimento barato.

- **Validação de e-mail (SEC-34):** a API ainda consulta o DNS do domínio informado, com limite de tentativas.
- **Profissionais criados pela clínica** não confirmam o e-mail.
- **Não testados aqui:** o Dockerfile sem root (sem Docker) e o firmware em hardware.

8. Revisão deste relatório

Para registrar quem conferiu o relatório e as ações depois do deploy.

REVISADO POR	FUNÇÃO	DATA

OBSERVAÇÕES GERAIS

Assinatura